

[AI-04] Reflective Statement

Trong seminar **T09 - Security Testing (DAST / SAST)**, nhóm em sử dụng AI như một công cụ hỗ trợ trong quá trình tìm hiểu, xây dựng workflow và rà soát kết quả, chứ không xem AI là nguồn kết luận cuối cùng. Việc dùng AI giúp nhóm tiết kiệm thời gian ở các bước dễ bị lặp lại như đọc tài liệu công cụ, phác thảo script, giải thích alert, gợi ý PoC, viết README và chuẩn hóa báo cáo. Tuy nhiên, càng làm sâu vào Semgrep và OWASP ZAP, nhóm càng thấy rõ rằng output AI chỉ có giá trị khi được đối chiếu lại với evidence thật.

Ở Track Semgrep, AI hỗ trợ nhóm giải thích finding `hardcoded-jwt-secret`, phân tích nguy cơ lộ JWT secret, gợi ý hướng tạo PoC và đề xuất remediation bằng biến môi trường. Những gợi ý này giúp nhóm hiểu nhanh hơn mối liên hệ giữa CWE-798, OWASP Authentication Failures và đoạn code dùng `jwt.sign/jwt.verify`. Tuy vậy, nhóm không dùng nguyên văn output AI. Ví dụ, AI có lúc dùng secret hoặc endpoint minh họa chưa khớp với source code. Nhóm phải sửa lại PoC để dùng đúng secret trong evidence, đối chiếu vị trí finding với `backend/server.js`, và gộp các cảnh báo liên quan thành một root cause thay vì phóng đại thành nhiều lỗi riêng lẻ.

Ở Track ZAP, AI hỗ trợ nhóm định hình script scan, parse report, tạo AI triage report, thêm các lựa chọn CLI như `--scan-mode`, `--report-format`, `--output-file`, và gợi ý cấu hình authenticated scan bằng JWT. Lợi ích lớn nhất là AI giúp nhóm nhìn được cấu trúc công việc: cần context, user, forced user, Replacer rule, AJAX Spider, report HTML/JSON và cleanup sau scan. Nhưng đây cũng là phần dễ sai nếu tin AI quá nhanh. Nhóm phải đối chiếu lại với tài liệu official của ZAP về Report Generation, scanners, authentication methods, users, Replacer và AJAX Spider. Những nội dung như tên template report, ý nghĩa tag OWASP, giới hạn của `basic/owasp-top10-2025`, hoặc lỗi `401/403` đều cần kiểm tra lại bằng code và môi trường local.

Một bài học quan trọng là AI có thể tạo cảm giác output đã hoàn chỉnh, trong khi thực tế vẫn thiếu precondition, expected result hoặc bằng chứng thực thi. Trong báo cáo audit, nhóm đã đánh dấu một số nội dung là `INCOMPLETE` vì AI chỉ gợi ý hướng kiểm chứng nhưng chưa có log, screenshot, request/response hoặc oracle rõ ràng. Ví dụ, với finding cleartext HTTP request, ý tưởng dùng proxy để quan sát token là hợp lý, nhưng muốn kết luận defect thì phải biết cấu hình runtime của `API_URL`, môi trường demo có yêu cầu HTTPS hay không, và phải lưu bằng chứng proxy. Tương tự, output

AI cho ZAP JSON report có phần ghi "Actual" như thể đã verify, nhưng nếu chưa kèm log Postman/ZAP thì không nên xem là bằng chứng cuối.

AI cũng giúp nhóm phát hiện nhu cầu kiểm soát chất lượng tốt hơn. Khi Semgrep báo nhiều finding cùng liên quan đến hardcoded JWT secret, nhóm nhận ra cần deduplicate theo root cause. Khi OpenRouter trả lỗi **402**, nhóm phải phân biệt lỗi do credit/token limit với lỗi code. Khi môi trường Python báo **externally-managed-environment**, nhóm chuyển sang dùng **.venv** thay vì cố cài package global. Những tình huống này cho thấy AI có thể hỗ trợ giải thích lỗi, nhưng quyết định xử lý vẫn phải dựa trên log, command thực tế và hiểu biết của người làm.

Qua quá trình này, nhóm rút ra rằng AI phù hợp nhất với vai trò "trợ lý kỹ thuật": giúp gợi ý hướng đi, diễn giải alert, phác thảo tài liệu và nhắc các bước kiểm chứng. AI không phù hợp để thay thế việc chạy Semgrep/ZAP, đọc source code, xác minh PoC hoặc kết luận mức độ nghiêm trọng. Với security testing, kết luận sai có thể dẫn đến false positive, false negative hoặc remediation không đúng trọng tâm, nên mọi output AI đều cần human validation.

Nếu làm lại quy trình, nhóm sẽ ghi prompt và output AI có hệ thống hơn ngay từ đầu, đặc biệt là lưu lại prompt gốc, output gốc, phiên bản đã sửa, lý do sửa và bằng chứng xác minh. Nhóm cũng sẽ tách rõ ba loại nội dung: AI hỗ trợ soạn thảo, AI hỗ trợ phân tích kỹ thuật, và bằng chứng kiểm thử do nhóm tự chạy. Cách tách này giúp báo cáo minh bạch hơn và tránh hiểu nhầm rằng AI tự sinh ra kết luận hoặc test case cuối cùng.

Kết luận, AI đã giúp nhóm làm seminar nhanh hơn và có cấu trúc hơn, nhưng giá trị thật sự chỉ xuất hiện khi nhóm biết kiểm chứng lại. Sản phẩm cuối cùng của nhóm không phải là output AI, mà là kết quả đã được con người đọc, chạy thử, đối chiếu evidence và chỉnh sửa. Đây cũng là bài học quan trọng nhất của nhóm khi dùng AI trong kiểm thử phần mềm: AI có thể hỗ trợ suy nghĩ, nhưng trách nhiệm kết luận vẫn thuộc về người kiểm thử.